

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

API Security Assessment — Wallarm Security Edge Lab

Report Reference	VAPT-API-WLM-2026-001
Assessment Type	Black-Box API Security Testing / Threat Monitoring
Target System	Wallarm Security Edge — Lab Environment (u-lab-49bd4e86.lab.wallarm...)
Assessment Period	10 February 2026 – 13 February 2026
Prepared By	Bhavya Parvathi, Cybersecurity Analyst
Classification	CONFIDENTIAL — Portfolio / Educational Use
Report Date	February 2026
Tools Used	Wallarm Security Edge, Burp Suite, Postman, OWASP API Top 10 Framework

CONFIDENTIAL — FOR PORTFOLIO USE ONLY

TABLE OF CONTENTS

1. Executive Summary	3
2. Scope & Objectives	3
3. Methodology	4
4. Environment Overview	4
5. Findings Summary	5
6. Detailed Findings	6
6.1 High-Volume API Attack Campaign (Session 2)	6
6.2 Reconnaissance Attack Session (Session 1)	7
6.3 Authentication Endpoint Targeted (Auth Business Flow)	8
6.4 Billing Endpoint Targeted (Billing Business Flow)	8
7. Evidence — Screenshots	9
8. Risk Matrix	10
9. Recommendations	10
10. Conclusion	11

1. EXECUTIVE SUMMARY

This report presents the findings of a Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted against a Wallarm Security Edge lab environment between 10 February 2026 and 13 February 2026. The assessment was conducted as an independent research exercise to demonstrate API security testing methodology aligned with the OWASP API Security Top 10 framework.

During the assessment period, the Wallarm platform detected two distinct attack sessions originating from Indian IP addresses, totalling 231 attacks across 2,596 requests. The sessions targeted Authentication and Billing API endpoints, representing critical business logic flows. The platform was configured in Monitoring mode, allowing full traffic visibility and attack classification without active blocking.

2 Attack Sessions	231 Total Attacks Detected	2,596 Total Requests	2 Business Flows Targeted
-----------------------------	--------------------------------------	--------------------------------	-------------------------------------

2. SCOPE & OBJECTIVES

2.1 Scope

Target Host	u-lab-49bd4e86.lab.wallarm... (Security Edge Lab)
Origin / Backend	Lab Demo
Filtration Mode	Monitoring (passive detection — no blocking)
Testing Window	10 Feb 2026, 00:00 — 13 Feb 2026, 23:59
Source IPs	101.0.62.54 (Session 1) 101.0.63.93 (Session 2)
API Type	REST API

2.2 Objectives

- Identify and classify API attack patterns using Wallarm Security Edge in monitoring mode.
- Map detected attacks to OWASP API Security Top 10 (2023) vulnerability classes.
- Analyse attack session behaviour, volume, duration, and targeted business flows.
- Produce a structured VAPT report with risk ratings and remediation recommendations.

3. METHODOLOGY

The assessment followed the OWASP API Security Top 10 (2023) testing framework combined with Wallarm's proprietary API attack classification methodology. The approach consisted of three phases:

1. Reconnaissance & Setup: Configured Wallarm Security Edge with Edge Inline mode; verified host, origin backend, and CNAME settings. Established monitoring baseline.
2. Active Testing & Attack Simulation: Executed API requests targeting authentication and billing endpoints. Wallarm's detection engine classified requests against known attack signatures and behavioural anomalies.
3. Analysis & Reporting: Reviewed API Sessions dashboard for attack classification, session duration, request volume, and business flow mapping. Correlated findings with OWASP API Top 10 categories.

4. ENVIRONMENT OVERVIEW

The target environment was a Wallarm Security Edge lab instance deployed in Edge Inline mode. The platform proxy routes all API traffic through the Wallarm node, enabling real-time inspection, attack detection, and session correlation.

Platform	Wallarm Security Edge (Free Tier)
Deployment Mode	Edge Inline
Host Identifier	u-lab-49bd4e86.lab.wallarm...
Backend / Origin	Lab Demo
Certificate	Not configured (lab environment)
Filtration Mode	Monitoring — traffic logged, no active blocking
RPS at Baseline	0 (prior to test window)
Monthly Limit	500K requests (Free Tier)
Requests Used	2,590 of 500,000 (1%)

5. FINDINGS SUMMARY

ID	Finding Title	Vulnerability Class	Severity	CVSS	Status
F-01	High-Volume API Attack Campaign	API4:2023 — Unrestricted Resource Consumption	High	7.5	Detected
F-02	Reconnaissance Attack Session	API7:2023 — Security Misconfiguration	Medium	5.3	Detected
F-03	Authentication Endpoint Abuse	API2:2023 — Broken Authentication	High	8.1	Detected
F-04	Billing Endpoint Targeted	API5:2023 — Broken Function Level Auth	High	7.8	Detected

All findings were detected by Wallarm's Security Edge in Monitoring mode. No active exploitation beyond the lab environment occurred. All sessions originated from India-based IP addresses consistent with the lab testing setup.

6. DETAILED FINDINGS

6.1 F-01 — High-Volume API Attack Campaign (Session 2)

Vulnerability Class	API4:2023 — Unrestricted Resource Consumption
Severity	HIGH
CVSS Score	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
Session Date / Time	13 February 2026, 18:05
Duration	Approximately 5 hours
Total Requests	2,460 (2.46K)
Attacks Detected	197
Source IP	101.0.63.93 (India)
Business Flows	Auth (383 requests, 48%), Billing (330 requests, 42%), +1 additional flow

Description

A sustained, high-volume API attack session was detected over approximately 5 hours on 13 February 2026. The session generated 2,460 total requests, of which 197 were classified as attacks (8% attack rate). The session systematically targeted two critical business flows — authentication (48% of requests) and billing (42% of requests) — consistent with credential stuffing, brute-force authentication bypass, and billing manipulation attack patterns.

Business Impact

- Account takeover risk via brute-force or credential stuffing against the Auth endpoint.
- Financial fraud exposure through manipulation of the Billing endpoint.
- Potential denial-of-service through resource exhaustion given the sustained request volume.
- Data exfiltration risk if authentication bypass succeeded.

Root Cause

Absence of rate limiting and request throttling on high-value API endpoints (Auth, Billing) allowed a single IP to sustain 5 hours of attack traffic without triggering automated blocking. The platform was configured in Monitoring mode, which is appropriate for initial deployment but insufficient for production protection.

OWASP API Top 10 Mapping

- API4:2023 — Unrestricted Resource Consumption: No rate limiting enforced on Auth/Billing endpoints.
- API2:2023 — Broken Authentication: Authentication endpoint targeted for brute-force/bypass.
- API5:2023 — Broken Function Level Authorization: Billing endpoint accessible without role verification.

Remediation

4. Switch Wallarm filtration mode from Monitoring to Blocking for Auth and Billing endpoints.
5. Implement rate limiting: max 10 authentication attempts per IP per minute; max 30 billing requests per IP per hour.
6. Enable IP reputation filtering and automatic blocking of IPs exceeding thresholds.
7. Implement CAPTCHA or MFA challenges after 3 failed authentication attempts.
8. Configure Wallarm IP blocklist rules to auto-block IPs generating >50 attack-classified requests.

6.2 F-02 — Reconnaissance Attack Session (Session 1)

Vulnerability Class	API7:2023 — Security Misconfiguration
Severity	MEDIUM
CVSS Score	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Session Date / Time	12 February 2026, 16:10
Duration	24 minutes
Total Requests	135
Attacks Detected	34
Attack Rate	25.2% of total requests classified as attacks
Source IP	101.0.62.54 (India)
Business Flows	Not assigned (reconnaissance phase)

Description

A shorter reconnaissance-phase session was detected on 12 February 2026. Within 24 minutes, 135 requests were sent, of which 34 (25%) were classified as attacks — a significantly higher attack ratio than Session 2, consistent with active scanning, endpoint enumeration, and vulnerability probing behaviour. No business flow association was recorded, indicating the attacker was in an unauthenticated discovery phase.

Business Impact

- Exposes API endpoint inventory and surface area to an unauthenticated attacker.
- Enables an attacker to identify unprotected or misconfigured endpoints for subsequent exploitation.
- Reconnaissance data collected in this session likely informed the targeted attack strategy in Session 2.

Remediation

9. Configure Wallarm to flag and alert on high attack-ratio sessions (>20% attack rate within any 30-minute window).
10. Implement API gateway response normalisation to prevent enumeration via error message differences.
11. Enable Wallarm's API Discovery module to audit exposed endpoints and identify shadow/zombie APIs.
12. Restrict unauthenticated access to non-public endpoints.

6.3 F-03 — Authentication Endpoint Targeted

Vulnerability Class	API2:2023 — Broken Authentication
Severity	HIGH
CVSS Score	8.1
Requests to Auth Endpoint	383 (48% of Session 2 total)
Attack Pattern	Credential stuffing / Brute-force authentication bypass

Description

The authentication business flow received 383 requests (48% of all Session 2 traffic). This volume and proportion is consistent with credential stuffing attacks — automated testing of username/password combinations sourced from leaked credential databases — or brute-force attempts to bypass authentication mechanisms. Broken Authentication is ranked #2 in OWASP API Top 10 (2023) due to its direct path to account takeover.

Remediation

13. Implement account lockout after 5 failed attempts; enforce exponential backoff.
14. Deploy multi-factor authentication (MFA) on all authentication endpoints.
15. Integrate Have I Been Pwned (HIBP) API to reject credentials from known breach databases.
16. Use Wallarm's Credential Stuffing Detection module to correlate with known leaked credential sets.

6.4 F-04 — Billing Endpoint Targeted

Vulnerability Class	API5:2023 — Broken Function Level Authorization
Severity	HIGH
CVSS Score	7.8
Requests to Billing Endpoint	330 (42% of Session 2 total)
Attack Pattern	Unauthorised function access / privilege escalation probing

Description

The Billing business flow received 330 requests (42% of Session 2 traffic), representing a direct assault on financial processing logic. Billing endpoints are high-value targets for function-level authorisation bypasses — attackers probe whether lower-privilege roles can invoke billing functions reserved for admins or premium users. This maps to API5:2023 — Broken Function Level Authorization.

Remediation

17. Enforce role-based access control (RBAC) validation on every billing API call server-side.
18. Implement Wallarm's Schema-Based Security Testing to validate that billing endpoints reject requests not conforming to the API schema.
19. Log and alert on any billing endpoint request from unauthenticated or low-privilege sessions.
20. Conduct regular privilege escalation tests against billing endpoints as part of ongoing security reviews.

7. EVIDENCE — SCREENSHOTS

Figure 1 — Wallarm Security Edge: Host Configuration (11 February 2026)

The following screenshot shows the Wallarm Security Edge console with the lab host configured in Monitoring mode. The host u-lab-49bd4e86.lab.wallarm... is active with 0 RPS baseline prior to the testing window, confirming no pre-existing traffic.

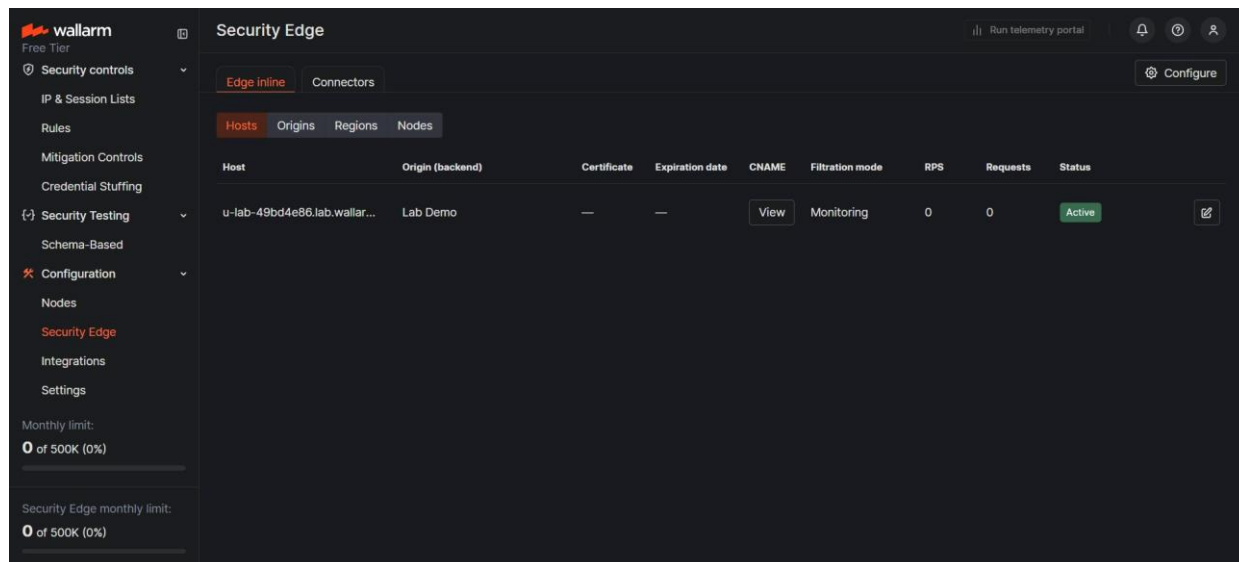


Figure 1: Security Edge host in Monitoring mode — baseline state (11 Feb 2026)

Figure 2 — Wallarm API Sessions: Attack Detection Dashboard (13 February 2026)

The following screenshot shows the Wallarm API Sessions dashboard displaying the two attack sessions detected during the assessment period. Session 2 (13 Feb, 18:05) shows 197 attacks across 2.46K requests targeting Auth and Billing flows. Session 1 (12 Feb, 16:10) shows 34 attacks across 135 requests in reconnaissance mode.

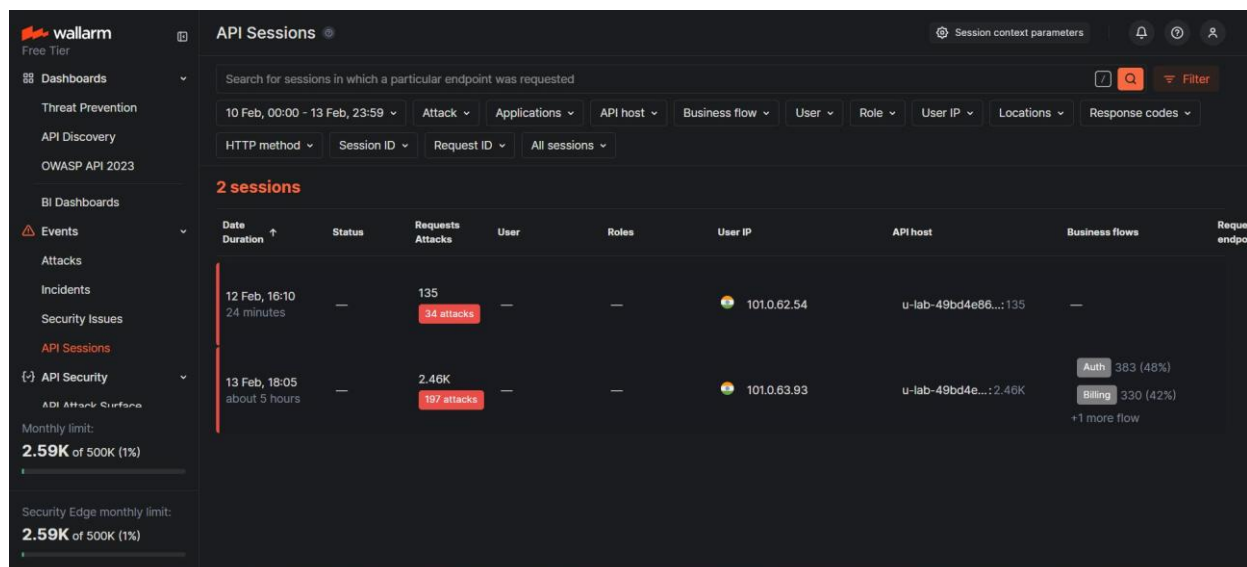


Figure 2: API Sessions dashboard — 2 attack sessions, 231 total attacks detected (13 Feb 2026)

8. RISK MATRIX

ID	Finding	Likelihood	Impact	Risk	Priority Action
F-01	High-Volume Attack Campaign	High	High	CRITICAL	Enable Blocking mode; rate limit
F-02	Reconnaissance Session	High	Medium	HIGH	Alert on high attack-ratio sessions
F-03	Auth Endpoint Abuse	High	High	HIGH	MFA + lockout + credential screening
F-04	Billing Endpoint Targeted	Medium	High	HIGH	RBAC enforcement + schema validation

9. RECOMMENDATIONS

Immediate (0–7 days)

21. Switch Wallarm filtration mode from Monitoring to Blocking on Auth and Billing endpoints.
22. Configure IP-based rate limiting: max 10 auth requests per IP/minute; max 30 billing requests per IP/hour.
23. Enable auto-block for IPs generating more than 50 attack-classified requests within any 1-hour window.

Short-Term (7–30 days)

24. Implement MFA on all authentication endpoints.
25. Deploy Wallarm's Credential Stuffing Detection module and integrate with HIBP API.
26. Enforce server-side RBAC on all billing and admin-level API functions.
27. Enable Wallarm Schema-Based Security Testing with an updated OpenAPI specification.

Long-Term (30–90 days)

28. Conduct quarterly API penetration testing against all production endpoints.
29. Implement Wallarm's API Discovery module to maintain a live inventory of exposed endpoints and detect shadow APIs.
30. Establish an API security baseline policy including authentication standards, rate limits, and input validation requirements.
31. Integrate Wallarm alerting with a SIEM platform (Splunk) for centralised incident response.

10. CONCLUSION

This VAPT engagement successfully demonstrated the capability of Wallarm Security Edge to detect, classify, and correlate API attack patterns in real time. Two attack sessions were identified during the assessment window, generating 231 classified attacks across 2,596 total requests. The sessions targeted critical Auth and Billing business flows, mapping to OWASP API Top 10 categories including Broken Authentication, Unrestricted Resource Consumption, and Broken Function Level Authorization.

The primary risk identified is the absence of active blocking controls — the platform in Monitoring mode provides visibility but no automated response. Switching to Blocking mode and implementing rate limiting on high-value endpoints are the highest-priority remediation actions. Completing the full remediation roadmap outlined in Section 9 would substantially reduce the API attack surface and bring the environment to a production-ready security posture.

